HEM Competition – Summary of Changes

Audit, PostgreSQL consolidation and modernisation · branch `claude/hopeful-ptolemy-qhwb7l` · 13 Nov 2026

1	0	6	89	−29k
database (PostgreSQL) was 2	SQL Server references left in code	game engines on one shared interface	automated tests, all passing	net lines in the repository (44.7k removed incl. unused models and old build output, 15.5k added)

1. What was found (audit)

Full report: `docs/01-AUDIT-REPORT.md`. The most serious findings in the original code:

#	Problem	Now
C1	No login required on any game, quiz or report endpoint – anyone could download all report CSVs (names, emails, scores).	Every endpoint requires a token of the right kind; a test fails the build if an endpoint is left open.
C2	Student id was read from the URL/body, so one student could read or write another's attempts.	The student is always taken from the token. No user ids in URLs.
C3	Answers were sent to the browser (Scramble, Word Challenge, Puzzle); Game 24 was checked only in JavaScript.	Solutions never leave the server; all answers are validated server-side.
C4	Quiz marks could be forged: any exam id accepted, score recomputed on every call.	Ownership checked, row locked, scored once from a frozen answer key.
C5	Anyone could log any student out (`terminate-session` was public).	Ending another session needs the password again.
C6	Any student token could change the competition dates.	Admin permission `competitions.manage` required.
C7	JWT key, SQL `sa` password and PostgreSQL password committed; 3 admins with one hard-coded password.	Secrets come from environment variables; existing admins must change password at next sign-in.
C8	The browser decided disqualification; it was instant, permanent, with no history, evidence or way back.	Server-side policy, full event history, evidence, suspension → review → appeal.

2. Single database

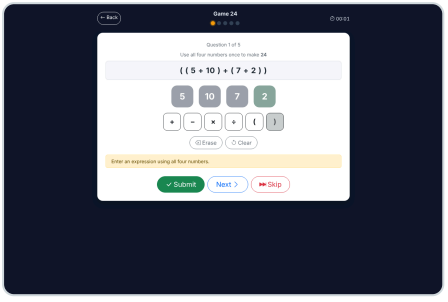
- Removed: SQL Server provider, Dapper, 357 scaffolded LMS entity classes, 19 stored-procedure calls.
- One `AppDbContext` with EF Core migrations. **Existing tables and data are kept**: on a database that already has the six original tables the baseline migration is recorded, not run; everything new is additive.

- Verified by an automated test that builds the old schema with real rows and upgrades it: old students sign in with their old passwords, previously disqualified students become ban records with an appeal option.
- 26 new tables (games, attempts, question bank, quizzes, proctoring, evidence, bans, appeals, roles, audit, settings). ER diagram: `docs/03-DATABASE.md`.

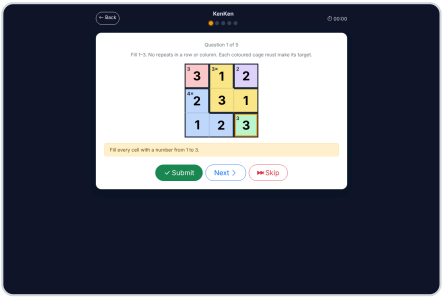
3. Games

Section	Game	How content is produced	How answers are checked
Number	Game 24	Generated; solver guarantees a solution exists	Expression parsed with exact fractions, each number once (no `eval`)
	KenKen	Generated Latin square + cages	By the rules
	Futoshiki ("Photosoky")	Generated, exactly one solution	By the rules
Word	Scramble	Generated from the word bank	Every row + final word
	Puzzle (word search)	Grid generated on the server	Each word must lie on a line in the grid
	Word Challenge	Clue from the word bank	Exact word
Mega Quiz	Quiz 1–4 (any number)	Question bank managed by admins	Server-side from a per-attempt snapshot

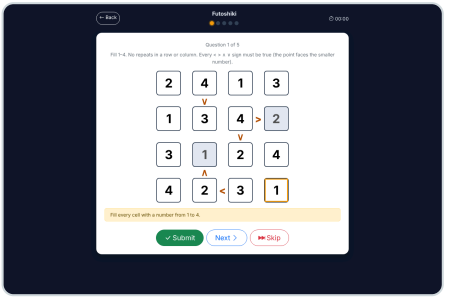
All six generated games share one interface (`IGameEngine`), one attempt pipeline, one set of tables and one set of API endpoints. Adding a game = one class + one row. Only the puzzle snapshot, the solution, the submission, score and time of each round are stored.



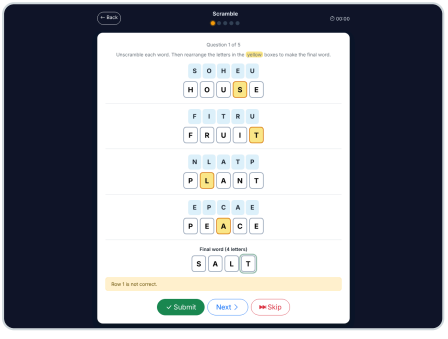
Game 24



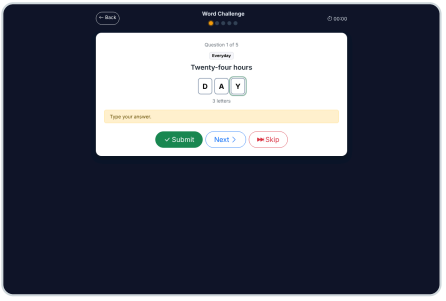
KenKen



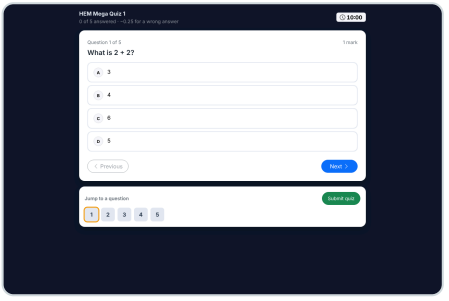
Futoshiki



Scramble



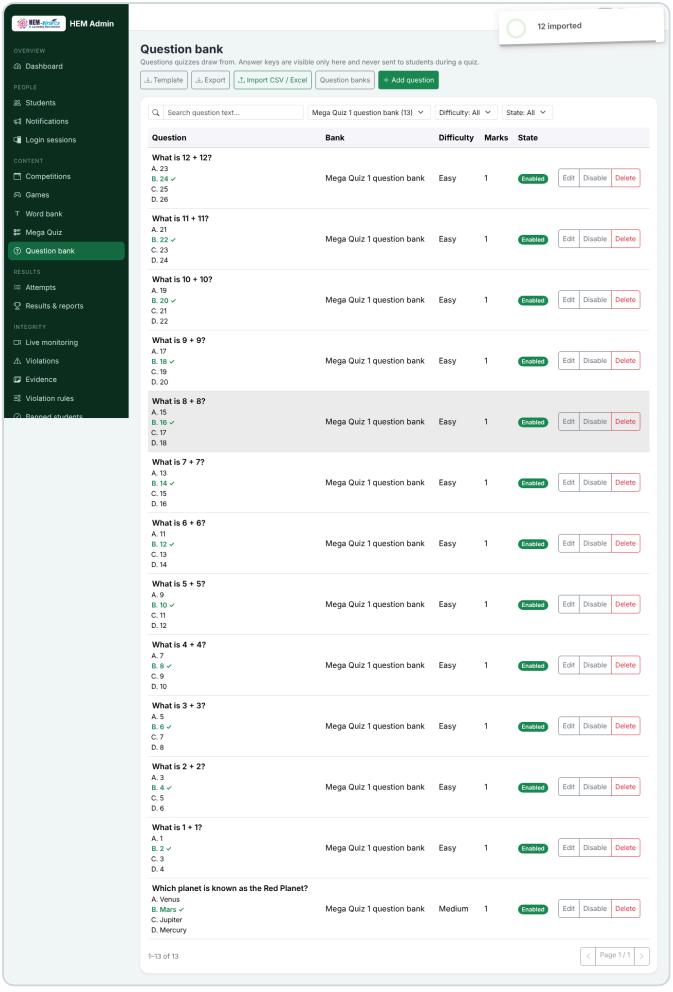
Word Challenge



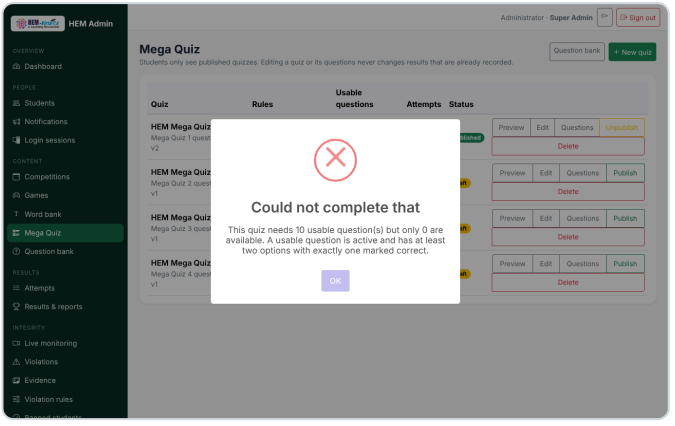
Mega Quiz

4. Mega Quiz management

- Question banks, questions with 2–8 options, one correct answer, explanation, image, difficulty, marks, enable/disable.
- Quiz rules: fixed or random selection from a pool, question count, duration, marks per question, negative marking, shuffle questions/options.
- Import from CSV or Excel (all-or-nothing, row-level error messages, no duplicates on re-import), export, template.
- Preview with answer key before publishing; publish refused if there are not enough usable questions.
- Each attempt stores a snapshot and the quiz version, so editing a question later never changes a recorded result (tested).
- Answer keys are released to students only if the competition publishes results **and** has ended.



Question bank

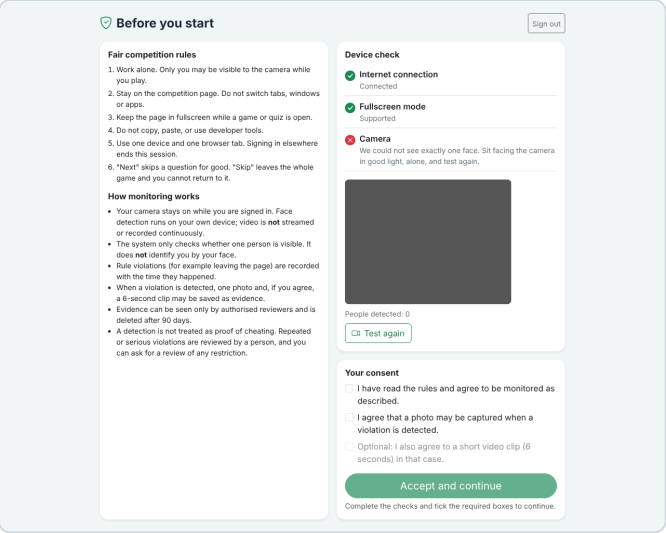


Quizzes – publish refused when empty

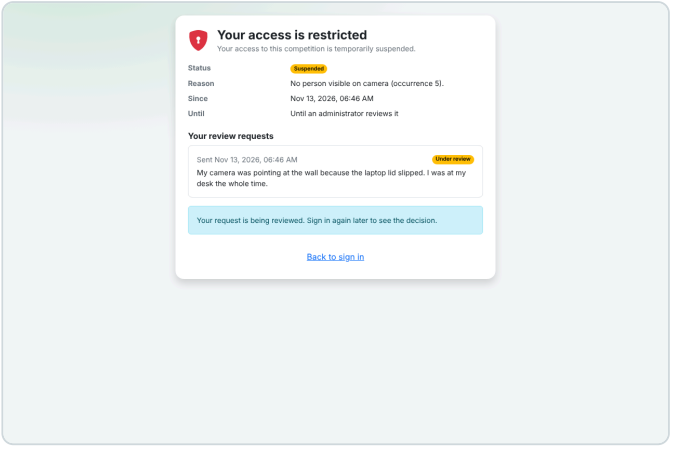
5. Anti-cheating, evidence, bans and appeals

Area	What was built
Consent	Rules and monitoring explained before the test; separate tick boxes for rules, photo evidence, and optional video. Camera starts only when the student presses the button. Changing the consent version makes everyone accept again.
Device check	Internet, fullscreen support, camera and "exactly one person visible" before continuing.

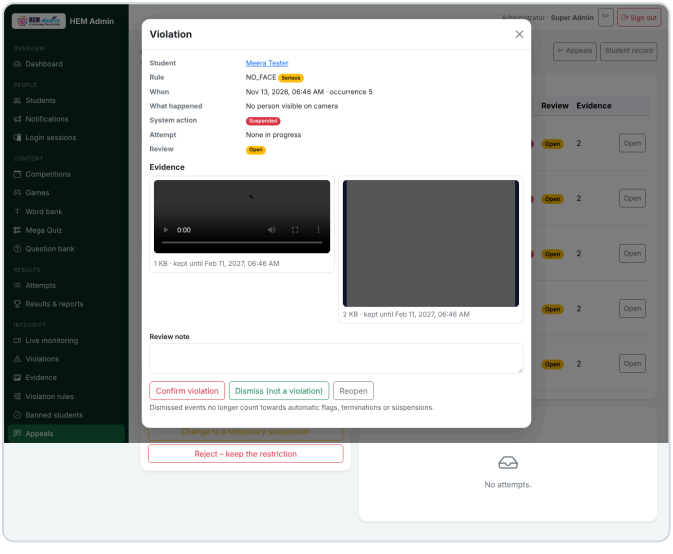
Monitored events	Tab switch, window blur, fullscreen exit, copy/paste, right-click, developer-tool shortcuts, page reload, duplicate tab, second login, network loss, camera off, no face, several faces.
Policy	14 configurable rules: severity, flag after N, end attempt after N, suspend after N (timed or until reviewed), capture photo / video. Dismissed events stop counting. Network loss has no penalty by default.
Evidence	Snapshot and short clip captured only when a rule fires and the student consented. Checked by file content, hashed, stored outside the web root, auto-deleted after the retention period. Only roles with `evidence.view` can open it; every view is audit-logged.
Privacy	Face detection runs on the device and only counts faces – no identification, no continuous recording, no streaming.
Bans	Automatic action stops at suspension; a ban is always an admin decision. Students cannot lift their own restriction.
Appeals	Restricted student sees the reason at sign-in and can request a review and track it. Reviewer sees ban, violation history, images/clips, attempts; adds internal notes; approves, rejects (reason required) or converts to a dated suspension. Filing an appeal never restores access by itself.



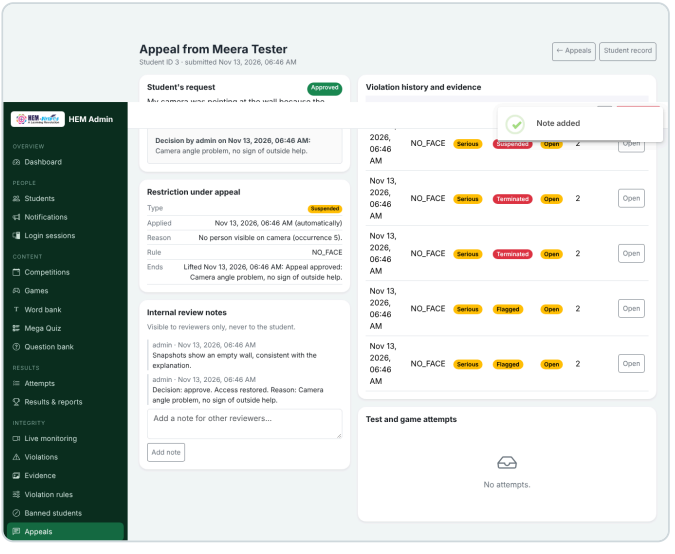
Consent and device check



Student appeal page



Reviewer viewing evidence

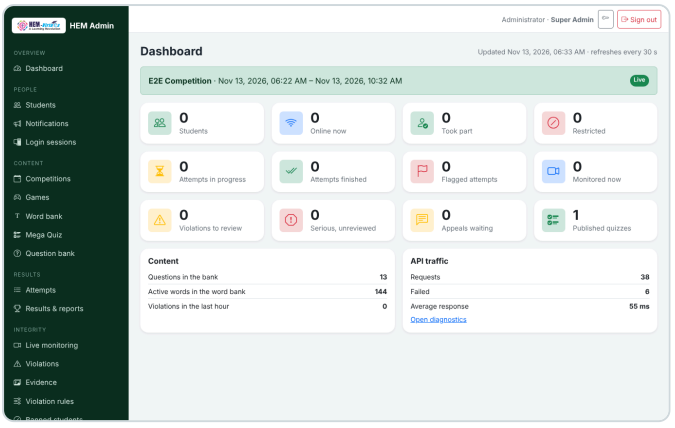


Appeal decision

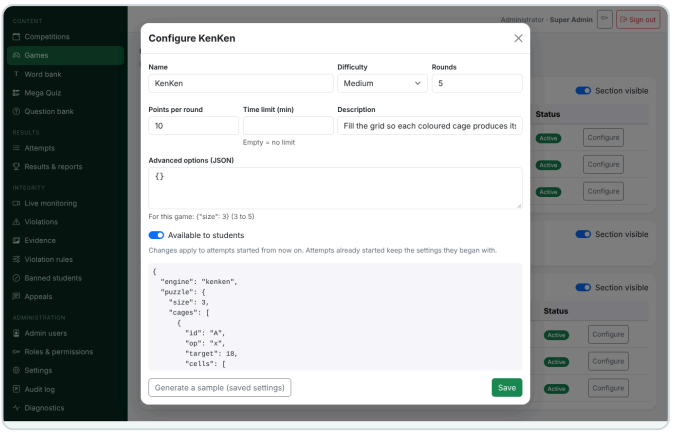
6. Admin panel and roles

22 screens: Dashboard, Students (+ detail, import, reset password), Notifications, Login sessions, Competitions, Games, Word bank, Mega Quiz, Question bank, Attempts (+ detail with puzzle / solution / submission), Results & reports (5 CSV reports), Live monitoring, Violations, Evidence, Violation rules, Banned students, Appeals, Admin users, Roles & permissions, Settings, Audit log, Diagnostics.

Roles: Super Admin, Admin, Quiz Manager, Competition Manager, Reviewer, Read-only Auditor, plus custom roles from 30 permissions. Permissions are enforced by the server on every request (a test fails if any admin endpoint lacks one).



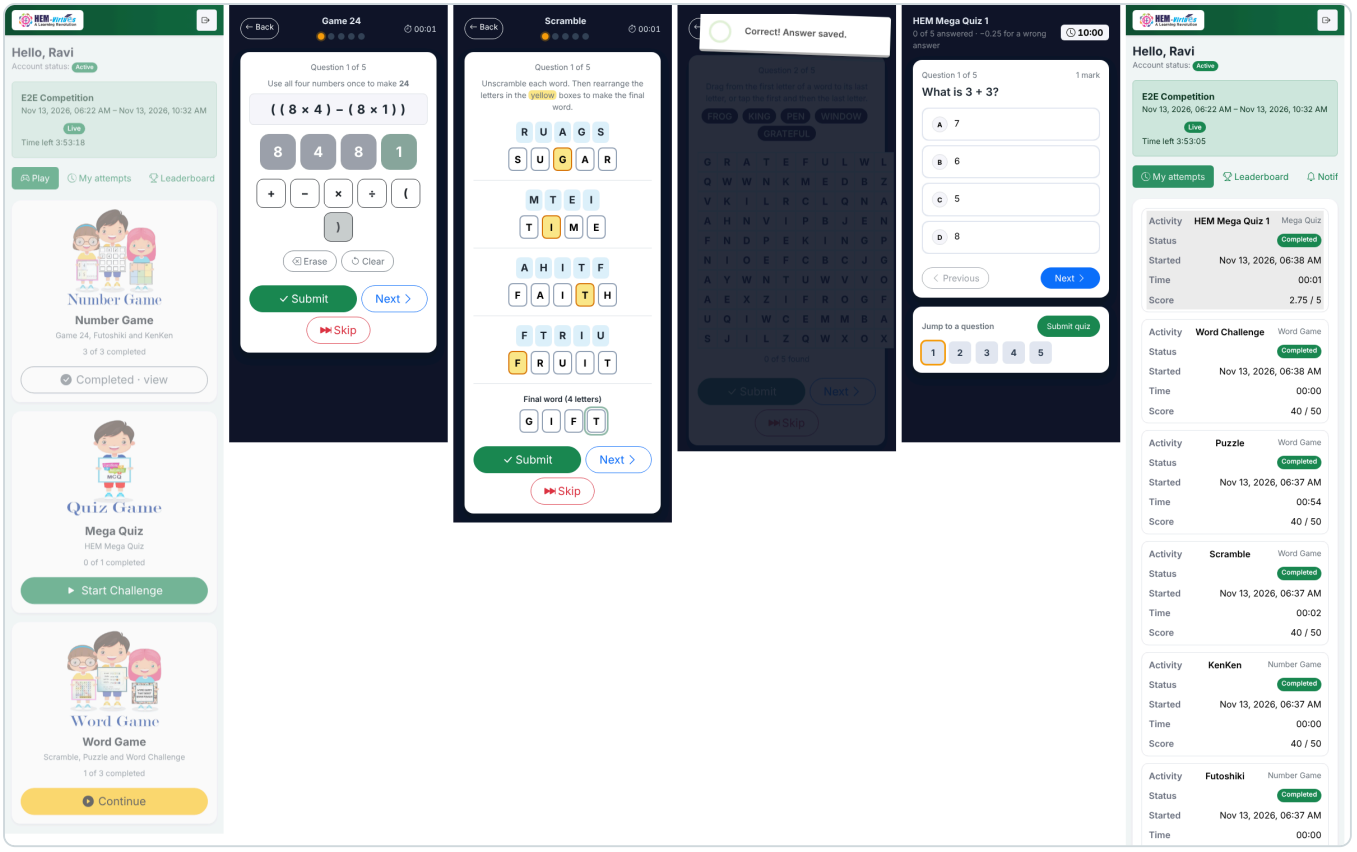
Admin dashboard



Game configuration with sample

7. Student panel

- Dashboard with the three sections, competition countdown, attempt history, leaderboard, notifications, profile.
- One play screen for all games: timer, progress, Submit / Next / Skip / Back as in the original guide; refresh or reconnect resumes the same round.
- Quiz: saved answer per question, question navigator, server-side timer, auto-submit, confirmation before submit.
- Mobile-first layout; tables become cards on phones; grids scale to the screen.



Phone (390 px): dashboard, Game 24, Scramble, Puzzle, quiz, history

8. Security hardening

Item	Implementation
Passwords	PBKDF2 (ASP.NET Identity); existing hashes still valid; rehash on login when needed.
Tokens	15-minute access token kept in memory (not localStorage); rotating refresh token in an HttpOnly SameSite=Strict cookie; re-use of an old token revokes the family.
Brute force	Account lockout, rate limits, identical error for unknown user and wrong password.
Browser	Content-Security-Policy (self only), no third-party CDNs (Bootstrap, icons, MediaPipe now served locally), nosniff, frame-ancestors none.
Uploads	Type detected from bytes, size limits, random storage keys outside the web root.
Integrity	Unique constraints + row locks prevent duplicate attempts and double submissions; scores cannot be edited, only reset with an audited reason.
Errors	Internal messages and stack traces are logged, never returned.
CSV export	Formula-injection safe.

9. How it was tested

Check	Result

Backend unit + integration tests (real PostgreSQL)	**89 / 89 pass** – engines, scoring, auth, token rotation, RBAC, legacy upgrade, each game end-to-end, quiz snapshots, proctoring escalation, evidence, appeals, reports.
Browser run, desktop 1280 px	**Pass** – login, consent, all 6 games played through the UI, quiz, violation, history, leaderboard.
Browser run, phone 390 px	**Pass** – same flow with touch.
Camera flow (blank camera feed)	**Pass** – precheck blocks; warnings; flag → attempt ended → suspension; photos and clips stored; appeal; admin views evidence and approves; student can sign in again.
Admin panel	**Pass** – forced password change, competition, question add/import, quiz preview/publish, students, all 22 pages render without errors.
Answer leakage	**None** – every student API response during the runs was scanned for answer keys.
Lint / builds	**Clean** – ESLint 0 problems, backend 0 warnings.

Bugs found by this testing and fixed: empty optional fields rejected when creating a student; leaderboard total 0 with a single participant; a hint disappearing in the word search; evidence for the event that triggers a suspension being lost.

10. What you need to do / what is not done

> **Needs your SQL Server database (I could not access it):** quiz questions and word lists must be exported to CSV and imported through the admin panel – queries are in `docs/04-MSSQL-EXPORT.md`. Until then the four Mega Quizzes exist but are unpublished, and the word games use a 144-word starter list. Scoring/selection rules that lived inside stored procedures were re-created from what the API and UI showed (5 rounds, 10 points per round, ties by time) – please confirm they match your rules.

> **Security actions on your side:** rotate the PostgreSQL password, set a new `Jwt__Key`, and take a `pg_dump` backup before the first deployment. The old secrets remain in git history.

Not implemented	Reason
Self-registration, forgot-password by email	Students are an imported eligible list and there is no email service configured; admins create/import students and reset passwords.
Email notifications, certificates	Need an email provider / certificate design; in-app notifications are implemented.
Copy of old results from SQL Server	No access to that data; export the old reports before switching it off.
Camera test with a real face / real devices	Automated test used a blank feed. A rehearsal on real phones and laptops is strongly recommended before a live event.
Load test at 16,000 students	Not possible in this environment; run one before the event.
Frontend unit tests	Frontend was verified by real-browser runs instead; no Jest/Vitest suite was added.
Multiple server instances	Rate limiting and caches are in-process; run one instance (see deployment guide).

11. Documents in the repository

File	Content
`docs/01-AUDIT-REPORT.md`	Original architecture, features, security mechanisms, issues, migration plan
`docs/02-ARCHITECTURE.md`	New architecture, game engine, quiz, auth, proctoring
`docs/03-DATABASE.md`	Tables, ER diagram, constraints, migrations
`docs/04-MSSQL-EXPORT.md`	Export queries for questions and words
`docs/05-DEPLOYMENT.md`	Environment variables, upgrade steps, build, backup/restore